

Login Bypass

Bối cảnh (Context)

Tập đoàn công nghệ GlobalTech vừa ra mắt một cổng thông tin nội bộ (Intranet Portal) hoàn toàn mới dành riêng cho Ban Giám đốc. Các kỹ sư của GlobalTech rất tự hào về giao diện hiện đại và tốc độ phản hồi cực nhanh của hệ thống này. Tuy nhiên, do áp lực phải bàn giao dự án đúng tiến độ, đội ngũ phát triển (Dev) đã bỏ qua khâu kiểm thử bảo mật độc lập và tiến hành deploy thẳng lên môi trường Production.

Gần đây, bộ phận giám sát an ninh mạng (SOC) phát hiện một số dấu hiệu truy cập bất thường vào tài khoản của Tổng Giám đốc (`admin`), mặc dù ông ấy đang đi công tác và không hề đăng nhập hệ thống. Đội SOC nghi ngờ rằng trang đăng nhập có thể đã không kiểm tra kỹ lưỡng dữ liệu đầu vào.

Mục tiêu (Objective)

- **Nhiệm vụ:** Bạn vào vai một chuyên gia Pentest được thuê để kiểm tra lại cổng thông tin này. Hãy tìm cách đăng nhập thành công vào tài khoản của quản trị viên (Admin) mà **không cần** phải biết mật khẩu thực sự của họ.
- **Vấn đề / Lỗi hổng:** Trang web dính lỗi **SQL Injection (SQLi)** cơ bản ở form đăng nhập. Mã nguồn có khả năng đã nối chuỗi (concatenate) trực tiếp input của người dùng vào câu lệnh SQL thay vì sử dụng Parameterized Queries.
- **Flag:** Sau khi đăng nhập thành công, bạn sẽ tìm thấy Flag nằm trong trang Dashboard của Admin.

Gợi ý (Hints)

- Bạn có biết ký tự nào thường được dùng để "đóng" một chuỗi trong cơ sở dữ liệu SQL không?
- Ký tự nào thường được dùng để comment (bỏ qua) phần còn lại của câu lệnh SQL?
- Hãy thử biến mệnh đề `WHERE` trong câu truy vấn SQL luôn trả về giá trị `TRUE`.